

Anil Seth



Security without Passwords

Passwords have their own inherent vulnerabilities. They are prone to being forgotten and sometimes being hacked. While a strong password can provide security, there are other larger issues involved. In this article, the author takes a look at various methods of online identity authentication other than the ubiquitous password.

The following example is indicative of the risk faced by most people when using technology for financial transactions (<http://goo.gl/aXfXoT>):

Sir Bernard Hogan-Howe, the metropolitan police commissioner, said customers who had fallen foul of online fraudsters were being “rewarded for bad behaviour” instead of being incentivised to update anti-virus software and improve passwords.

At least from newspaper reports, it would appear that it is not easy for Indian consumers to get back their money in case of online frauds. The sad part is that in an effort to be ‘easy to use’, security considerations have taken the back seat and now it is tough to find alternate means of tightening security. Fixing bad systems is never easy.

For example, <https://goo.gl/MgJMCh> reports that Google hopes to allow passwordless authentication on Android phones by taking into account “...a combination of signals — like your typing patterns, your walking patterns, your current location, and more.”

Client certificates for authentication

Identity management has been an issue since the start of the Internet revolution. X.509 certificates date back to 1988. X.509 requires certificates to be issued by a certification authority (CA). A CA is needed in order to ensure trustworthiness of a certificate. An organisation could set up its own CA using openssl and issue certificates to each of its users. Its Web server has to be configured to authenticate those using client certificates.

As users import their client certificate into their browser, they will get access to the website and not be required to take any further action.

However, hardly anyone uses such authentication. The reasons are not hard to understand.

Distribution of the certificates is complex. It's hard for users to manage their certificates. Moving certificates across

devices or even browsers is also quite a complex task.

Smart cards for authentication

Some of the problems associated with client certificates can be managed by placing the certificate on a smart card. The smart card reader can be enabled in Firefox using the *Preferences > Advanced > Certificates > Security Devices* options. The US Department of Defence is probably still a major user of this method. But authentication using smart cards has not picked up in spite of the availability of USB tokens which eliminate the need for a smart card reader.

While this method eases the issues of a user managing client certificates across multiple devices, there remains the issue of how to manage keys. You certainly would not like to carry around different smart cards for different sites.

An interesting example is the Estonian ID card (see Wikipedia) which “...is also used for authentication in Estonia's ambitious Internet-based voting programme.” Any organisation in Estonia could, in principle, trust the public key of a person using the Estonian ID card.

There is even an OpenPGP card. The key pair is stored on the card; however, the private key can never be extracted from it. You may, however, replace the key-pair with a new set.

The card works along with the GnuPG software for digital signing and cryptographic purposes. It is also available as a USB token.

Universal Two Factor (U2F) standard

You might have come across the two-step authentication introduced by Google. One of the options is to use a security key developed by Google and Yubico for two-step verification in Google accounts. It is currently also used by Dropbox and GitHub. The key is supported by Chrome. Currently, an add-on is needed, which enables the security key to be used in Firefox.

Google has been immensely influential in making servers switch to HTTPS. The company may succeed in getting individuals to use security certificates as well! The price of